信息安全测评与风险评估

等保2.0标准体系框架学习

授课教师：张玉



目录

CONTENTS

01 案例导入——“一次扫描引发的连锁反应”

02 学习目标

03 漏洞扫描——在等保测评中的定位

04 漏洞扫描的核心原理

案例导入——“一次扫描引发的连锁反应”

引入问题：漏洞扫描就是在系统上“逛一圈”，发现问题就出报告吗？

某政务服务平台在等保测评前，自行使用漏洞扫描工具进行了一次“全面扫描”。结果如下：

- 扫描发现“高危漏洞”15个，“中危漏洞”42个
- 安全负责人看到报告后，按照CVSS评分最高开始修复
- 修复了3个“高危漏洞”后，业务系统出现异常——无法正常登录
- 紧急回滚后，测评机构进场，发现那3个被修复的“漏洞”其实是扫描工具的误报

问题讨论

Q1 为什么扫描工具会报告“误报”？

（基于规则匹配的特征码扫描，难免与正常配置“撞车”）

Q2 如何区分“真漏洞”和“假漏洞”？

Q3 看到扫描报告后，第一步应该做什么？

学习目标

通过本课学习，你将能够：



理解 漏洞扫描的基本原理（基于漏洞库的特征匹配）



掌握 常见漏洞扫描工具（Nessus/OpenVAS）的基本使用方法



能够 正确解读漏洞扫描报告（区分风险等级、识别误报）



能够 将扫描结果与等保测评指标关联，填写《漏洞扫描结果分析表》



具备 脆弱性分析与风险判断能力

漏洞扫描——在等保测评中的定位

GB/T 22239-2019 8.1.4.4 e）安全计算环境——入侵防范：应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞。

等保测评中的三种技术手段

方法	定义	在等保测评中的作用
访谈	与管理人员交流，获取证据	了解安全管理制度、人员配置
核查	查验文档、设备配置	验证配置是否符合基线
测试（含漏洞扫描）	使用工具产生结果，与预期比对	发现脆弱性、验证安全措施有效性

漏洞扫描在测评中的具体位置

1

测评阶段

现场测评 → 技术测试环节

2

对应标准

GB/T 22239安全计算环境 → 入侵防范

3

输出物

《漏洞扫描报告》

（每个系统1份，含主机+Web）

漏洞扫描的核心原理

核心定义

漏洞扫描是基于已知的漏洞数据库，通过模拟攻击行为检测目标系统是否存在可被利用的缺陷的自动化过程。

关键点

漏洞扫描是“基于特征码的匹配”——工具只能发现已知漏洞，无法发现0day。

技术原理三步走

1. **端口扫描**
   探测目标开放端口
   使用Nmap等工具
2. **服务识别**
   通过协议特征判断版本
   例：OpenSSH 7.4
3. **漏洞匹配**
   与CVE/NVD漏洞库对比
   生成报告

常见扫描类型

主机漏洞扫描

检查操作系统补丁、配置错误

工具：Nessus、Lynis

Web应用扫描

模拟SQL注入、XSS攻击

工具：AWVS、Burp Suite

数据库扫描

检查权限配置、弱密码

工具：DBScan

常见漏洞扫描工具介绍

工具	类型	特点	适用场景
Nessus	商业（有免费版）	漏洞库更新快、覆盖面广、界面友好、报告能力强	企业级、合规要求高
OpenVAS	完全开源	无授权费用、社区活跃、支持大规模扫描	成本敏感、教育/实验环境
Nmap	开源	网络发现、端口扫描、服务识别	信息收集、资产发现

重点工具： Nessus 和 OpenVAS

素材4：Nessus与OpenVAS对比（选

实践任务1——OpenVAS漏洞扫描操作

要素	内容
任务名称	使用OpenVAS对靶机进行漏洞扫描
任务环境	西普平台-漏洞扫描与结果分析-Windows漏洞扫描
操作步骤	实验指导书
任务产出	截图保存扫描结果（高危漏洞列表）



素材3：OpenVAS快速操作手册.docx

如何正确解读漏洞扫描报告

风险等级分类（CVSS评分体系）：

Critical（严重）

CVSS分值：9.0-10

建议时限：24-48小时

High（高危）

CVSS分值：7.0-8.9

建议时限：3-7天

Medium（中危）

CVSS分值：4.0-6.9

建议时限：7-30天

Low（低危）

CVSS分值：0.1-3.9

建议时限：30-90天

报告关键字段解读：

字段	含义	关注要点
漏洞名称	漏洞的CVE编号/描述	确认是否知名漏洞（如永恒之蓝）
影响主机	哪些IP/系统受影响	判断是单点问题还是共性问题
风险等级	CVSS评分	确定修复优先级
漏洞描述	漏洞的技术细节	理解漏洞原理
修复建议	推荐的修复方法	判断是否可操作

– 如何识别和验证误报（10分钟）

误报的常见原因

原因	示例	验证方法
版本号误判	基于banner识别版本，与实际不符	登录系统确认实际版本
配置误判	扫描工具认为默认配置=不安全	检查实际配置是否有补偿措施
网络环境干扰	防火墙、IDS导致响应异常	在本地网络重新扫描
漏洞已修复但未更新扫描缓存	补丁已安装但扫描库未及时更新	对比补丁安装记录

验证误报的三步法

1. **查看漏洞详情**
   阅读扫描报告中的“漏洞描述”和“验证方法”
2. **手动验证**
   登录目标系统，检查配置文件/补丁状态
3. **对比确认**
   使用另一款工具交叉验证，或咨询运维人员

扫描结果与等保测评的对应关系

等保测评中漏洞扫描结果的应用场景：

等保测评维度	漏洞扫描发现的对应问题	测评判定
安全计算环境-身份鉴别	存在弱口令漏洞	影响身份鉴别合规性
安全计算环境-入侵防范	存在未修复的高危漏洞	直接导致入侵防范不符合
安全区域边界-访问控制	开放了高危端口（如3389、22）	边界防护策略不严
安全区域边界-入侵防范	扫描发现可利用漏洞	说明入侵防范能力不足

关键认识： 漏洞扫描报告中的高危漏洞，通常直接对应等保测评中的“不符合项”。

实践任务2——漏洞扫描结果分析表填写

素材1：模拟漏洞扫描报告（用于实践

素材2：漏洞扫描结果分析表.docx

要素	内容
任务名称	填写《漏洞扫描结果分析表》（见素材2）
任务场景	教师提供一份模拟漏洞扫描报告（脱敏数据）（见素材1）

任务内容

01 从报告中提取漏洞信息

02 按风险等级分类

03 判断是否影响等保合规

04 提出整改优先级建议

漏洞管理闭环（拓展知识）

漏洞扫描只是起点，完整的漏洞管理需要形成闭环。漏洞管理六步法：



等保2.0要求：

应定期开展安全测评，发现的安全漏洞应及时修补或采取其他有效补救措施。

漏洞修复优先级判断

不是所有漏洞都需要立即修复——要结合CVSS评分 + 业务重要性。

优先级判断矩阵：

漏洞等级	资产重要性	修复优先级	建议时限
Critical	核心系统	最高	24小时
Critical	非核心系统	高	3天
High	核心系统	高	3天
High	非核心系统	中	7天
Medium/Low	任意	低	纳入计划

思政融入——漏洞扫描中的职业道德

授权

- 进行漏洞扫描必须先获得授权（书面）
- 未经授权扫描他人系统属于违法行为
- 等保测评中的扫描必须在授权范围内进行

客观

- 如实记录扫描结果
- 不隐瞒高危漏洞，不夸大风险等级

负责

- 扫描结果直接影响客户的安全判断
- 误报的识别和解释，体现测评师的专业水准

漏洞扫描报告不仅是技术文件，更是测评师职业操守的“照妖镜”。

知识点回顾（5分钟）

漏洞扫描与结果分析

- **一、漏洞扫描原理**
  - 基于漏洞库的特征匹配
  - 类型：主机/Web/数据库扫描
- **二、常用工具**
  - Nessus（商业，功能强）
  - OpenVAS（开源，成本低）
- **三、报告解读**
  - CVSS风险等级（Critical→Low）
  - 名称/影响主机/风险等级/修复建议
  - 误报识别：版本误判、配置误判
- **四、与等保测评的关联**
  - 对应标准：8.1.4.4 入侵防范
  - 高危漏洞→等保不符合项
- **五、漏洞管理闭环**
  - 资产识别 → 扫描 → 分析 → 修复 → 验证 → 报告

下节课预告：任务5：安全管理测评

预告内容

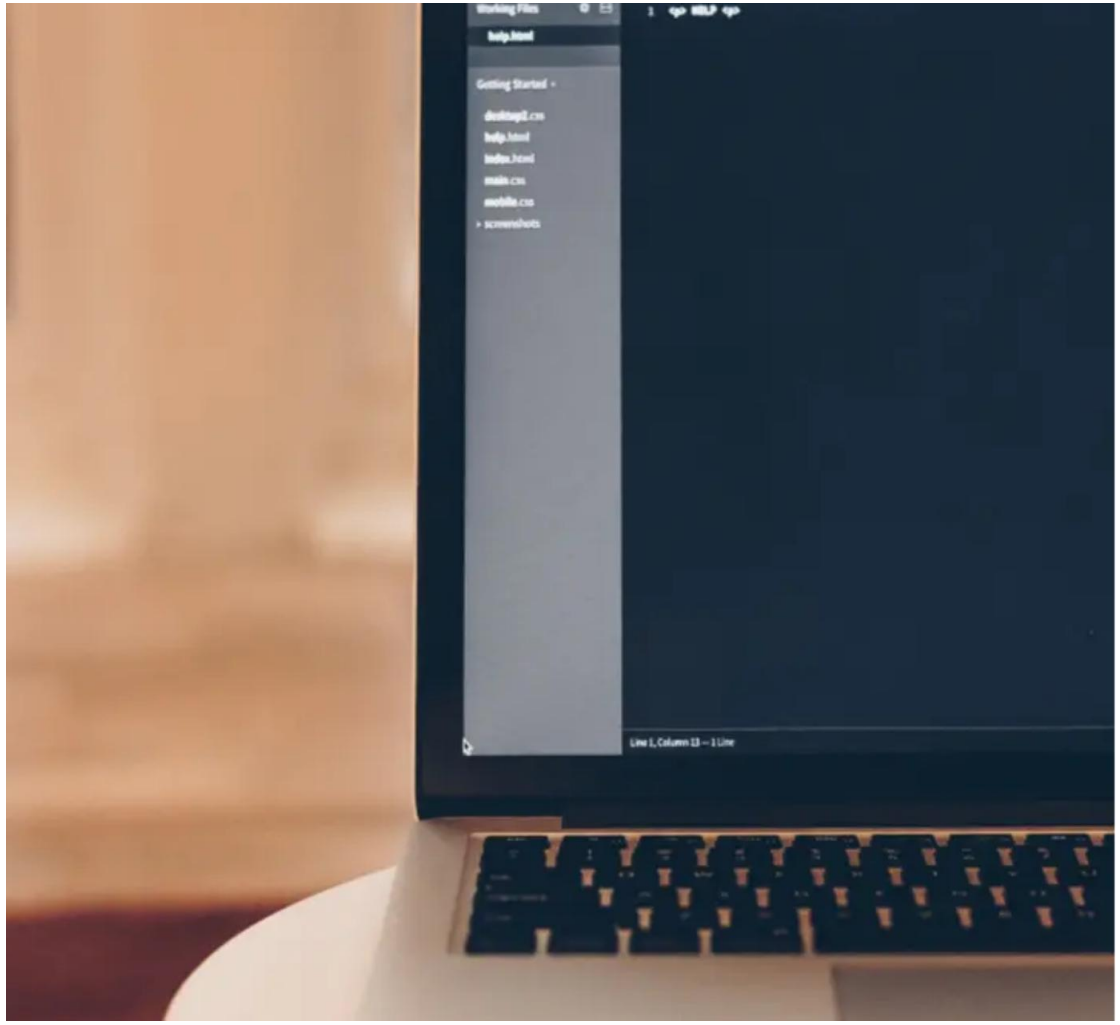
1. 安全管理测评五个核心维度
   制度、机构、人员、建设、运维
2. 文档核查方法
3. 模拟人员访谈

课前准备

- 复习GB/T 22239“安全管理”章节
- 阅读安全管理相关制度文件示例

页面标题

第20页：课堂小结与答疑 要素 内容
三个核心知识点：① 漏洞扫描的原理是基于漏洞库的特征匹配；② 报告解读要关注风险等级和误报；③ 高危漏洞直接对应等保不符合项
两个关键技能 ① 能使用Nessus/OpenVAS执行扫描；② 能正确解读扫描报告并识别误报 一个职业准则 未经授权不得扫描他人系统 开放答疑： 5分钟 【设计要求：结尾页】



感谢观看

